Playbooks de Respuesta a Incidentes — Cliente A

> **Nota sobre anonimización.** Este informe documenta un trabajo real, realizado con autorización del propietario. El nombre del cliente y los identificadores de su infraestructura se reemplazaron por marcadores (`Cliente A` , `cliente-a`) antes de publicarlo. Belona Cybersecurity no publica datos identificables de un cliente sin su autorización por escrito.

Manual de respuesta a incidentes de seguridad. Estructura basada en el ciclo **NIST** (Preparación → Detección → Contención → Erradicación → Recuperación → Lecciones aprendidas). Uso: seguir el playbook correspondiente ante el incidente.

Contactos y accesos clave

> Esta sección la completa el cliente con sus propios datos antes de que el playbook entre en uso. Un procedimiento de respuesta sin teléfonos reales no sirve: en un incidente nadie tiene tiempo de buscarlos. - Responsable técnico: **Belona Cybersecurity** — contact@belonacyber.com - Responsable de datos / legal: **legal@cliente-a.example** - Consola Firebase: https://console.firebase.google.com/project/cliente-a - Repo: github.com// - Autoridad de protección de datos (Colombia): **SIC** — sic.gov.co

---

Playbook 1 — Sitio comprometido / defacement (alerta del FIM)

Disparador: llega una alerta del monitoreo de integridad ("CAMBIO en ") o el job FIM queda en rojo.

1. **Detección/Verificación:** abrir el sitio en incógnito y comparar; revisar el log del FIM (qué archivo cambió). ¿Fue un deploy legítimo tuyo? → si sí, regenerar baseline y cerrar. Si NO →
2. **Contención:** si hay contenido malicioso, redeployar de inmediato la versión buena desde Git (`firebase deploy --only hosting`) o hacer rollback del hosting en la consola. Considerar poner el sitio en mantenimiento.
3. **Erradicación:** identificar cómo entró el cambio: ¿se filtró una credencial de deploy? ¿acceso al repo? Rotar credenciales de Firebase/GitHub. Revisar Actions/commits recientes.
4. **Recuperación:** confirmar sitio limpio (FIM en verde), regenerar baseline.
5. **Lecciones:** documentar causa raíz y reforzar el control que falló.

Playbook 2 — Cuenta de admin comprometida / acceso no autorizado

Disparador: actividad extraña en los **Logs** del panel, cambios de rol no reconocidos, login sospechoso.

1. **Contención inmediata:** en Firebase → Authentication → **deshabilitar** la cuenta sospechosa. Si es un abogado, quitarle el rol desde el panel (Usuarios) o poner `role: ninguno` .

2. **Investigación:** revisar la sección **Logs** (auditoría) — qué acciones hizo, sobre qué recursos, cuándo. Revisar Cloud Logging.
3. **Erradicación:** forzar cambio de contraseña; verificar/reactivar MFA; revocar sesiones.
4. **Recuperación:** revertir cambios no autorizados (usar backups/PITR si tocó datos).
5. **Lecciones:** ¿alcanzó el MFA? ¿hace falta reducir privilegios?

Playbook 3 — Fuga de datos personales (Data Breach) — Ley 1581

Disparador: exposición o acceso no autorizado a datos de clientes (consultas, expedientes, documentos).

1. **Contención:** cerrar el vector (reglas, permisos, tumbar el recurso expuesto).
2. **Evaluación:** qué datos, de cuántos titulares, sensibilidad (datos financieros/legales = alta).
3. **Notificación legal (OBLIGATORIA en Colombia):** - Notificar a la **SIC** (Superintendencia de Industria y Comercio) el incidente. - Informar a los **titulares afectados** según la política de tratamiento. - Coordinar con el área legal (es un estudio jurídico: seguir el proceso formal).
4. **Erradicación/Recuperación:** corregir la causa, rotar lo comprometido.
5. **Lecciones:** registrar en el expediente de cumplimiento.

> Nota: los plazos y la forma exacta de notificación los define el área legal. Este playbook solo recuerda la obligación.

Playbook 4 — Credencial / secreto expuesto

Disparador: se encuentra un token/clave/contraseña en un lugar público (repo, sitio, logs) — ej. el hallazgo `.git` del pentest.

1. **Contención:** quitar la exposición de inmediato (borrar el archivo, redeployar).
2. **Rotar la credencial YA:** revocar y regenerar el secreto comprometido (GitHub token, API key, contraseña de app de Gmail, etc.). Asumir que ya fue visto.
3. **Investigación:** ¿qué permisos tenía? ¿se usó? Revisar logs de acceso.
4. **Prevención:** mover secretos a Secret Manager; nunca en el repo ni en el hosting.

Playbook 5 — Pérdida / borrado de datos

Disparador: datos faltantes o borrados (accidental o malicioso).

1. **No entrar en pánico ni escribir sobre la base** hasta evaluar.
2. **Recuperar** según el runbook de backup: - Reciente (≤7 días) → **PITR** - Hasta 14 días → **backup diario** (restaurar a base nueva) - Documentos borrados → **versionado de Storage** - Ver: `recuperacion-ante-desastres.md`
3. Validar la restauración antes de reemplazar producción.

4. **Lecciones:** ¿por qué se borró? ¿hace falta más restricción o confirmaciones?

Preparación (mantener siempre listo)

- Backups activos y **probados** (test de restauración periódico).
- FIM y Logs funcionando (detección).
- MFA en todas las cuentas admin.
- Este documento accesible offline.
- Saber cómo: deshabilitar una cuenta, redeployar hosting, rotar secretos, restaurar backup.